

SOFTWARE SUPPLY CHAIN SECURITY

AI가 쏟아내는 코드, 무엇을 신뢰할 것인가

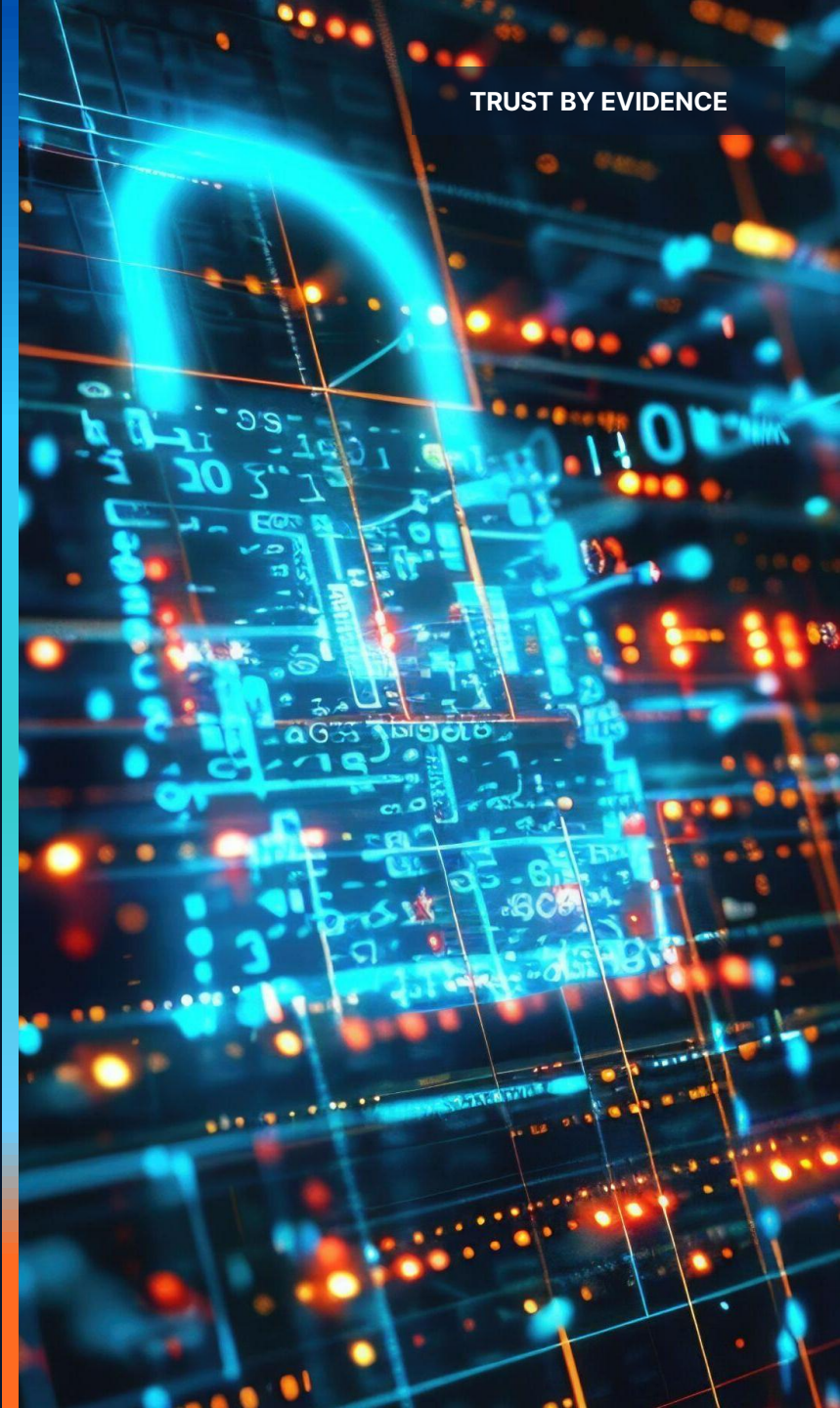
| SBOM·VEX와 실제 공격 위협 기반 소프트웨어 공급망 거버넌스 |

박준석

엘에스웨어(주)

오픈소스사업본부 본부장 / 상무

2026. 08. 11 | COEX, SEOUL



INDEX

무엇을, 어떤 순서로 다루는가

AI가 쏟아내는 코드, 무엇을 신뢰할 것인가 – 신뢰 체인을 따라가는 여섯 단계

1. 신뢰의 공백

AI 코드가 만드는 문제와 위협모델

2. 규제와 정책

OWASP · CRA · 국내 정책이 요구하는 책임

3. 신뢰할 수 있는 SBOM

구성 · 관계 · 출처를 함께 증명한다.

4. 위험 판단과 우선순위

실제 악용 X 제품 영향 기반의 결정

5. 실행 아키텍처와 거버넌스

파이프라인 위에서 실행되는 정책

6. 현장 적용과 90일 실행

금융 · 제조 사례부터 실행 계획까지

7. 결론: 신뢰의 기준

설명 가능한 결정 · 신뢰의 질문

30분 뒤, 세 질문에 답할 수 있어야 합니다.

제품 기능이 아니라 의사결정 체계와 운영 원리를 중심으로 봅니다.

1 무엇을 믿을 것인가

패키지 목록을 넘어 실제 배포물의 구성요소를 어떻게 확인할 것인가

2 무엇부터 고칠 것인가

수천 건의 취약점 중 실제 공격 가능성과 사업 영향을 어떻게 가릴 것인가

3 어떻게 증명할 것인가

VEX·정책·승인 이력을 연결해 대응과 면제 근거를 어떻게 남길 것인가

TRUST CHAIN

판단이 흐르는 순서

SEE → DECIDE → PROVE → CONTROL

- 1 식별
- 2 우선순위
- 3 VEX 판단
- 4 자동 통제
- 5 감사 증적

AI 코드의 문제는 속도가 아니라 '신뢰의 공백'이다.

코드는 더 빨리 생산되지만,
조직이 그 코드의 출처와 위험을 설명하는 속도는 따라가지 못하고 있습니다.

코드 생산량

AI-ASSISTED DEVELOPMENT

검증 역량

REVIEW CAP

TRUST GAP

\$1,380억

공급망 공격 글로벌 피해액 전망 '31 — '23년(\$460억)의 3배 (정부 로드맵)

54%

AI 생성 코드의 IP-라이선스를 점검하는 조직 비율 (OSSRA 2026)

보안의 질문은 “취약점이 있는가”에서
“왜 이 코드를 신뢰할 수 있는가”로 이동합니다.



THREE QUESTIONS TO PROVE

01 출처

생성 코드의 원본 프로젝트와 패키지를 설명할 수 있는가?

02 구성

바이너리·컨테이너·코드 조각까지 빠짐없이 식별하는가?

03 영향

VEX와 승인 이력으로 '영향 없음'을 감사 가능하게 증명하는가?

THREAT MODEL

공격자는 코드가 아니라 '신뢰 경로'를 노린다.

한 단계의 취약점보다, 검증 없이 다음 단계로 전달되는 신뢰가 더 위험합니다.

TRUST PATH



ATTACK SURFACE

평균 지속 253일 · 악성 패키지 '25년 45만+건 (정부 로드맵 · Sonatype)

자격 증명 → 코드 변경 → 빌드 실행 → 산출물 교체 → 배포 승인 → 운영 신뢰

핵심 포인트

'누가 만들었는가'보다 '어떤 증거를 거쳐 전달되었는가'를 검증해야 합니다.

ZERO TRUST FOR CODE

코드에도 Zero Trust가 필요하다.

외부 입력은 검증 전까지 신뢰하지 않고, 각 단계가 다음 단계에 '증거'를 전달해야 합니다.



TRUST RULE

신뢰는 계정에 부여하는 권한이 아니라, 전환마다 획득하는 증거입니다.

AI 생성 코드의 문제는 '목록에 남지 않는 유입'이다.

매니페스트 기반 점검만으로는 복사된 코드, 바이너리, 컨테이너 계층의 출처를 설명하기 어렵습니다.

**핵심 포인트**

매니페스트의 흔적이 약한 입력이 실제 공급망 사각지대다.

A03는 취약점 하나가 아니라 소프트웨어 전달 체인의 실패를 묻는다.

식별되지 않은 구성요소, 불안정한 빌드, 신뢰되지 않은 배포가 하나의 공격면으로 연결됩니다.

A03

SOFTWARE SUPPLY CHAIN FAILURES

01 INPUTS

패키지·AI 코드·3rd-party



02 BUILD & DEPENDENCIES

CI 권한·빌드 스크립트·전이 의존성



03 RELEASE & DISTRIBUTION

아티팩트·레지스트리·업데이트 채널



50%

커뮤니티 설문 응답자가 1위 위협으로 지목

8.17점

평균 Exploit 평가

5.23점

평균 Impact 평가

어디에서 신뢰가 끊겼는가?

CRA는 취약점 발견 이후 24시간의 운영 능력을 요구한다.

보고 시간표는 보안팀만의 일이 아니라 제품·법무·경영 의사결정이 연결된 사고 대응 체계입니다.

D-31

2026.09.11
취약점 보고 의무
적용 시작

'27.12 CRA 전면 적용
CE 마킹 필수 요건 ('24.12 공포)

설계 질문

발견 시각, 영향 제품,
완화조치, 보고 근거를
누가 즉시 모을 것인가?

DETECTION / CSIRT

탐지·초기 분류



조기 경보



PRODUCT SECURITY

영향 제품·버전 확인



완화·패치 계획



LEGAL / REPORTING

초기 통지



상세 보고

최종 보고



0h

24h

72h

조치

1mo

필수 증적

SBOM · 영향 분석 · 조치 상태 · 의사결정 책임자 · 제출 시각

국내 정책이 가리키는 결론 '취약점 발견 후의 책임'을 증명하라

SBOM 제출만이 아니라 영향 판단, 시정조치, 보고와 감사 증거까지 하나의 책임 체계로 연결해야 합니다.



ACCOUNTABILITY CHAIN



공통 요구

SBOM → 영향 분석 / VEX → 시정조치·보고 → 감사 가능한 의사결정 기록

국내 정책은 2026년부터 공공 조달·검증 체계를 구축한다.

첨부 로드맵은 SBOM 생성에서 끝나지 않고 VEX, 취약점 대응, 안전한 개발방법론까지 단계적으로 제도화합니다.



시장 진입 조건

문서 제출이 아니라 지속 업데이트 + 실제 영향 판단 + 조치 증적

신뢰할 수 있는 SBOM은 구성·관계·출처를 함께 설명한다.

SBOM

소프트웨어를 구성하는
부품과 관계를
기계가 읽을 수 있는 형태로
기록한 자재명세서

좋은 SBOM은
한 번 생성한 목록이 아니다.
빌드·배포·운영 상태와 함께 갱신되는
살아 있는 증거이다.

최소한 이 정보는 정확해야 한다.

컴포넌트 이름·버전

공급자·작성자

PURL / CPE

의존관계

해시·출처

생성도구·시간

표준	강점	적합한 활용
SPDX	라이선스·저작권·패키지 관계 표현에 강함	컴플라이언스, 조달, 감사 증적
CycloneDX	보안·서비스·취약점·VEX 생태계와 긴밀	AppSec, 취약점 관리, 운영 자동화

패키지 목록만으로는 실제 소프트웨어를 설명할 수 없다.

선언된 의존성



패키지 매니저와 빌드 파일이 알려주는 영역

직접·전이 의존성

저장소 메타데이터

빌드 시점의 이름과 버전



선언된 목록
실제와 다르다

실제 배포물에 존재하는 것



소스 외부와 사후 빌드 산출물에서 유입되는 영역

네이티브·Java·NET 바이너리와 벤더 SDK

컨테이너 OS 패키지와 레이어별 구성요소

복사·AI 생성 코드 조각, 펌웨어, 3rd-party 산출물

핵심 포인트

불완전한 SBOM은 위험을 줄이지 않는다.

누락된 구성요소는 취약점 알리도, 라이선스 검토도, 사고 시 영향분석도 받지 못한다.

신뢰 체인은 '탐지'가 아니라 증거의 연속성으로 완성된다.

무엇이 들어왔는지 보고, 무엇을 고칠지 결정하고, 왜 괜찮은지 입증한 뒤, 다시 유입되지 않게 통제합니다.



신뢰 = 모든 전환에서 살아남는 증거

신뢰할 수 있는 SBOM은 '센서 융합'의 결과다.

패키지 목록 하나가 아니라 서로 다른 탐지 방식이 동일한 산출물을 교차 검증해야 합니다.



COMPONENT	ORIGIN	VERSION	LICENSE	VULNERABILITY
openssl 3.0.13	npm · binary · snippet	버전·해시 고정	Apache-2.0	CVE·VEX 매핑

우선순위는 CVSS가 아니라 '실제 악용 × 제품 영향'으로 결정된다.

2026 정부 로드맵도 CVSS 중심 평가의 한계를 지적하고, 내·외부 위협DB 결합 탐지·대응체계를 추진합니다.

EVIDENCE INPUTS



핵심 포인트

결론은 점수가 아니라 '누가, 무엇을, 언제까지'의 형태로 운영 큐에 들어가야 한다.

EPSS와 CISA KEV를 결합하면 '지금 위험한 것'이 보인다.



두 지표가 답하는 질문

향후 30일 내
실제 악용될 확률은
얼마나 되는가?

이미 현실 공격에서 악용된
취약점인가?

SBOM이 재고목록이라면, VEX는 의사결정의 증거다.

정확한 구성요소 식별과 실제 제품 영향 분석이 연결될 때만 반복 가능한 취약점 대응과 면제 근거가 만들어집니다.

EVIDENCE INPUTS

CODE / BINARY 소스·바이너리·컨테이너
SBOM 구성요소·버전·경로
THREAT INTEL CVE·CVSS·EPSS·KEV
PRODUCT ONTEXT 호출경로·배포·자산 중요도



VEX DECISION STATES

NOT AFFECTED 영향 없음 + 근거
AFFECTED 조치·완화 필요
FIXED 조치 완료
UNDER INVESTIGATION 책임자·기한 지정

DECISION LEDGER

OWNER	TIME	RATIONALE	ACTION	DUE
판단 책임자	검토·보고 시각	판단 근거	패치·완화·면제	완료·재검토 기한

핵심 포인트

정책이 요구하는 것은 VEX 파일 자체가 아니라, 판단 근거가 위변조 없이 반복 검증되는 운영 체계다.

정책은 파이프라인 위에서 실행되고, 증거는 아래에 남아야 한다.

사람의 승인에 의존하지 않고 각 전환점에서 신뢰를 검증하는 운영 구조가 되어야 합니다.

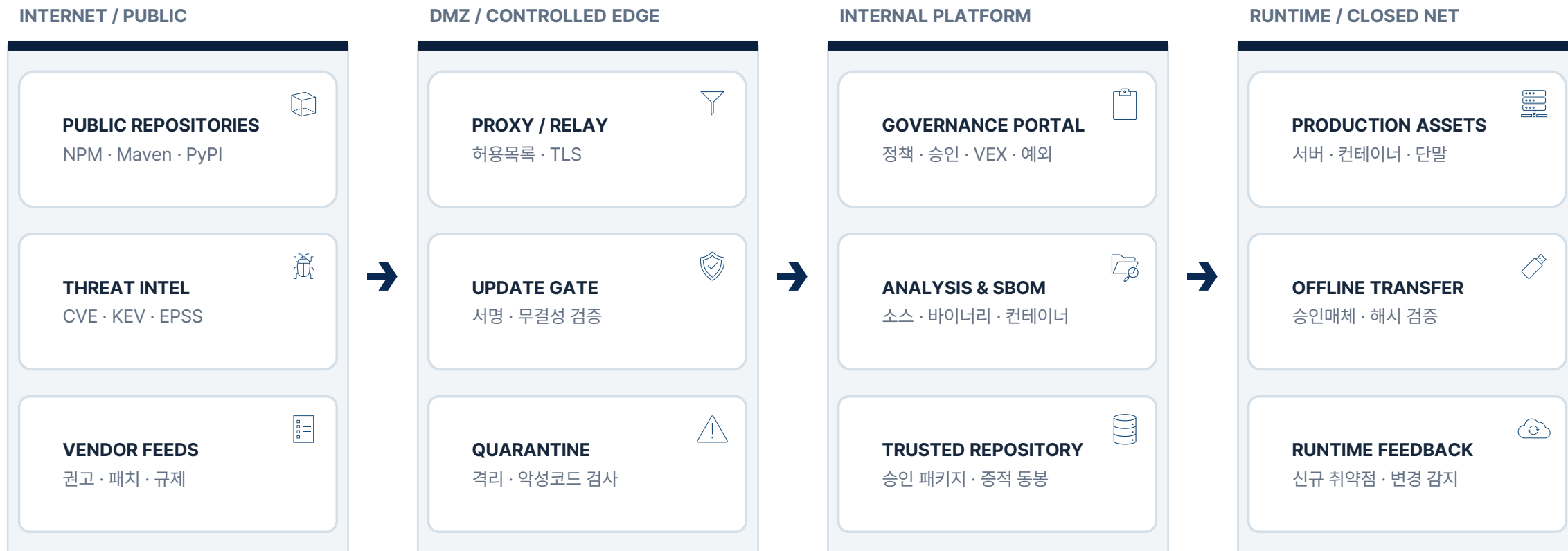


핵심 포인트

탐지 도구의 수보다 전환점별 검증과 증거의 연속성이 중요하다.

망 분리 환경에서도 업데이트 경로와 증적 경로는 끊기면 안 된다.

외부 인텔리전스는 경계에서 검증하고, 내부 산출물은 서명·SBOM·VEX와 함께 이동합니다.

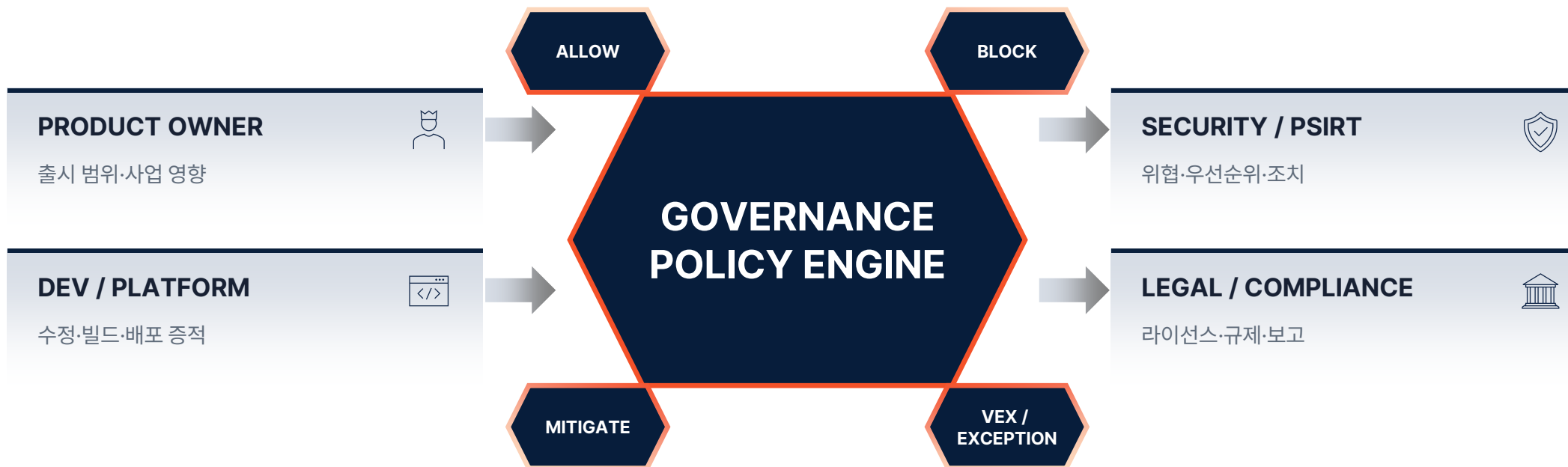


증적 계층

요청·승인 로그 | 서명·해시 | SBOM / VEX | 정책 판정 | 자산 상태

정책 엔진은 조직의 판단을 대신하지 않고, 같은 기준으로 연결한다.

개발·보안·법무·사업 책임자가 동일한 증거를 보고 각자의 결정을 남기는 구조가 필요합니다.

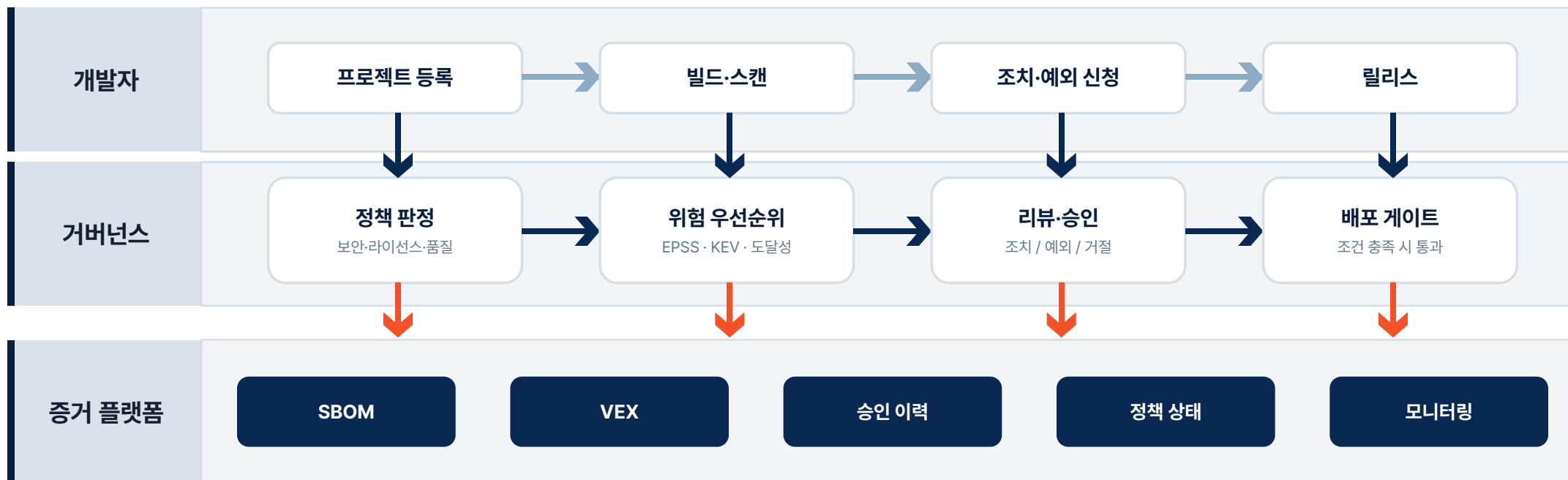


핵심 포인트

모든 결정에는 근거, 책임자, 기한, 재검토 조건이 함께 기록되어야 한다.

금융권의 핵심 전환은 '점검 요청'에서 '지속 통제'로의 이동이다.

역할·승인·예외·증거를 하나의 운영 흐름으로 묶어야 규제 대응과 개발 속도가 동시에 살아납니다.



운영 결과

감사 대응

판단 근거가 남는다.

개발 속도

고위험만 집중한다.

지속 통제

신규 위험을 다시 판정한다.

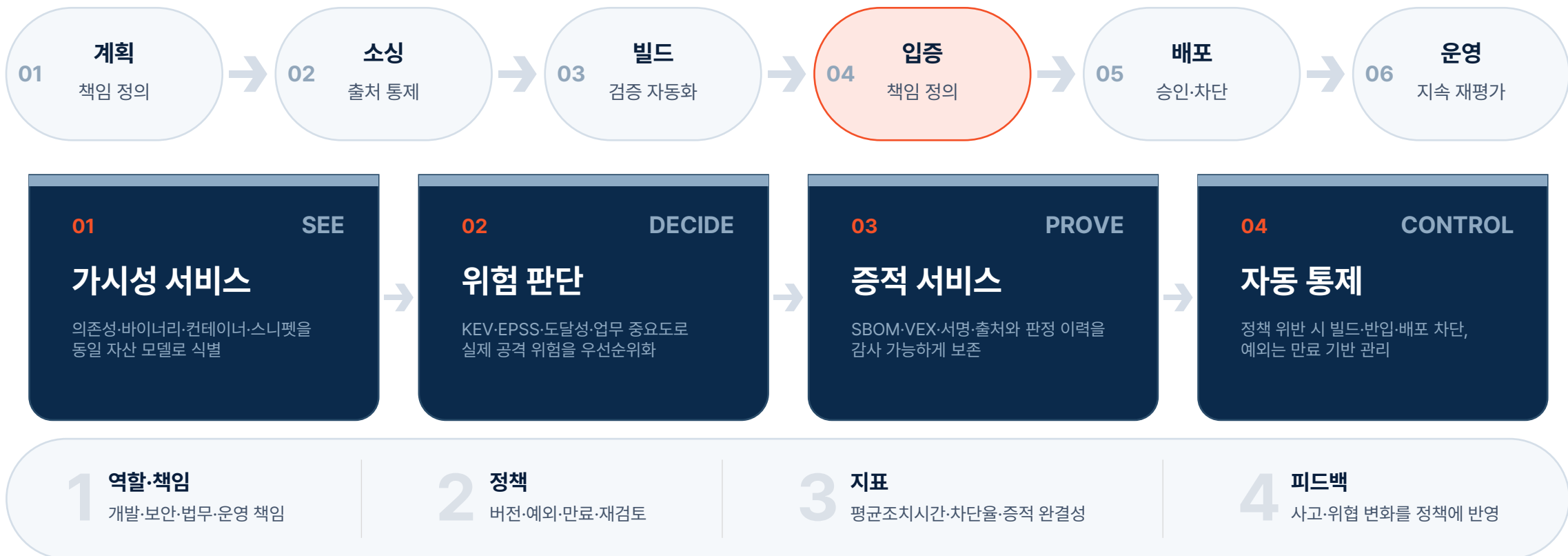
소스가 없는 산출물도 '증거 여권'을 통과해야 배포한다.

바이너리·펌웨어·컨테이너·AI 모델까지 구성, 출처, 실제 영향, 승인 이력을 하나의 신뢰 게이트에서 검증합니다.



공급망 보안은 도구가 아니라 운영 모델로 완성된다.

개발 흐름을 멈추지 않으면서 신뢰를 입증하는 네 가지 공통 서비스로 운영 모델을 구성합니다.



핵심 포인트

개발 속도를 지키는 방법은 보안을 '검토 단계'가 아니라 '기본 경로'로 만드는 것이다.

90일이면 '도구 도입'이 아니라 '통제 가능한 파일럿'을 만들 수 있다.

범위를 좁히고, 판단 기준을 고정하고, 운영 증거를 남기는 순서로 진행합니다.

DAY 30

DISCOVER

기준선 확보

- 핵심 제품 1~2개 선정
- 코드·바이너리·컨테이너 식별
- SBOM 품질 기준 정의

GATE 1 · 범위 승인

DAY 60

DECIDE

판단 체계 고정

- EPSS·KEV 우선순위 적용
- VEX 상태·근거 템플릿 확정
- 예외 승인·만료 기준 수립

GATE 2 · 정책 승인

DAY 90

CONTROL

운영 게이트 적용

- CI/CD 정책 게이트 적용
- 릴리스 증거 패키지 생성
- 신규 취약점 재평가 운영

GATE 3 · 운영 전환

90일 후 성과

설명 가능한 의사결정 + 감사 가능한 증거 + 자동화된 최소 통제

목표는 '취약점 0'이 아니라 설명 가능한 결정이다.

모든 취약점을 없앨 수는 없습니다.
그러나 무엇을 보고, 왜 미뤘고, 언제 다시 판단할지는 증명할 수 있습니다.

SEE

식별

+

DECIDE

우선순위

+

PROVE

VEX·증거

+

CONTROL

정책·자동화

**TRUST**

증거가 의사결정을 통과하고, 그 결정이 운영 정책으로 되돌아갈 때 신뢰가 만들어집니다.

여러분의 조직은 무엇을 신뢰하고 있습니까?

사람도, 도구도, SBOM도 그 자체로는 답이 아닙니다.

증거가 끊기지 않는 '신뢰 체인'을 설계하십시오.

SEE → DECIDE → PROVE → CONTROL

박준석 | 엘에스웨어(주) 오픈소스사업본부 본부장 / 상무

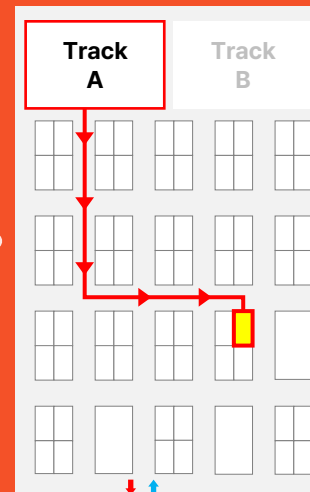
jspark@lsware.co.kr

010-7133-5099

ISEC 2026 | 2026. 08. 11

**F08 엘에스웨어
부스에서
직접 확인하세요.**

📷 이 장표를 촬영한 후
F08 엘에스웨어
부스에 방문하여 직원에게
보여주시면, 행운의 뽑기
응모권 1회를 드립니다!



- 1 AI 코드 조각 식별
- 2 신뢰 가능한 SBOM 생성
- 3 EPSS·KEV 우선순위
- 4 VEX·정책 게이트

DEMO | Q&A

감사합니다.